

CYBERSECURITY

LAB 10

1. Introduction

Information gathering is the first phase in penetration testing process. In this phase, we try to collect as much information as we can about the target, for example, information about the Domain Name System (DNS) hostnames, IP addresses, technologies and configuration used, username's organization, documents, application code, password reset information, contact information, and so on. During information gathering, every piece of information gathered is considered important. Information gathering can be categorized in two ways based on the method used: active information gathering and passive information gathering.

In the active information gathering method, we collect information by introducing network traffic to the target network. While, in the passive information gathering method, we gather information about a target network by utilizing a third-party's services, such as the Google search engine. After we have gathered information about our target network from third-party sources, such as search engines, the next step would be to discover our target machines.

The purpose of this process is as follows:

A. To find out which machine in the target network is available. If the target machine is not available; we won't continue the penetration testing process on that machine and move to the next machine.

B. To find the underlying operating system used by the target machine.

Collecting the previously mentioned information will help us during the vulnerabilities mapping process.

We can utilize the tools provided in Kali Linux for the target discovery process.

Most of these tools are available in the Information Gathering menu, with the following submenus:

A. Identify Live Hosts

B. OS Fingerprinting

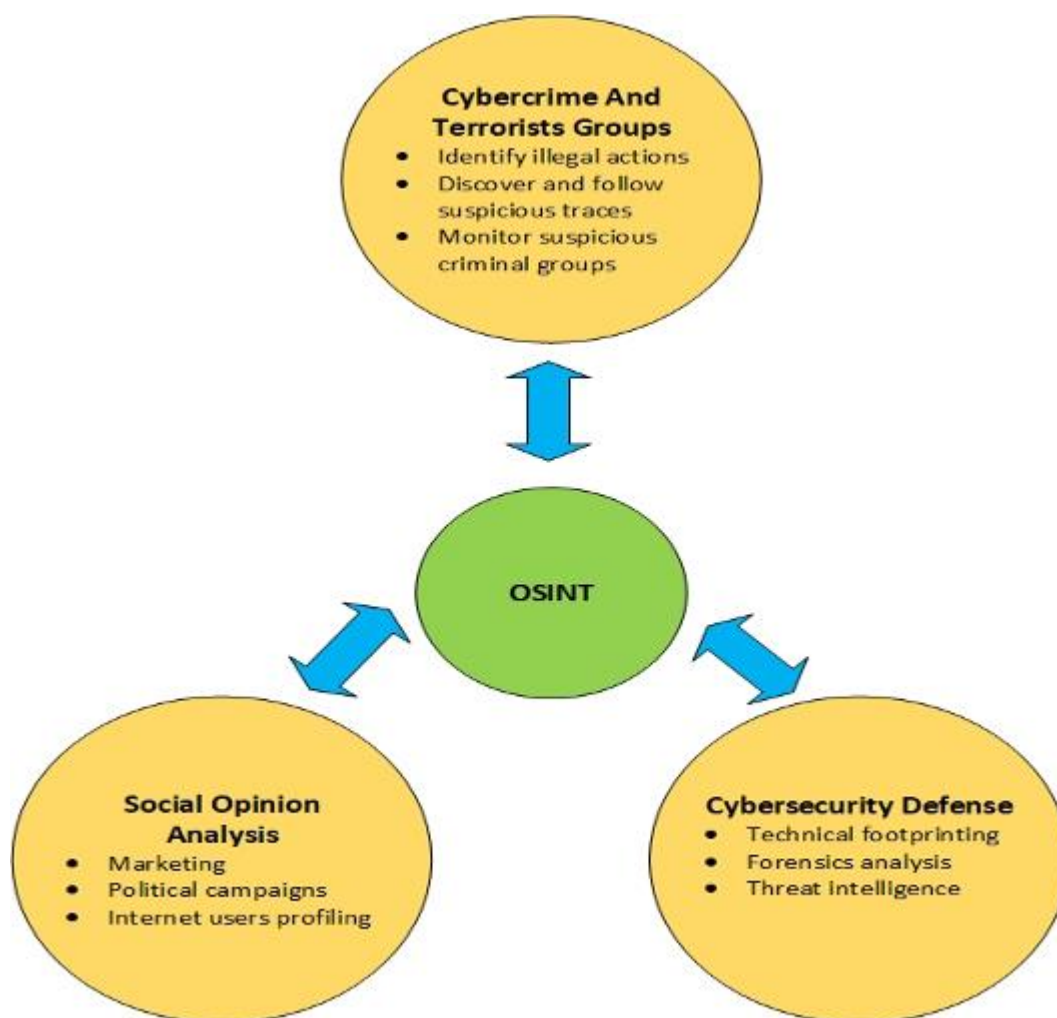
OSINT (Open Source Intelligence) is intelligence derived from public information--tailored intelligence which is based on information which can be obtained legally and ethically from public sources. On the Internet, there are several public resources that can be used to collect information regarding a target domain. The benefit of using these resources is that your network traffic is not sent to the target domain directly, so our activities are not recorded in the target domain logfiles.

In terms of cybersecurity, OSINT is mainly used to optimize attacks against specific users and to carry out social engineering attacks. A typical scenario is to use information about people related to the target of the attack: date of birth, work, school to crack passwords. "Humans are incapable of securely storing high-quality cryptographic keys..."¹ and despite many password security policies, quite simple keys are still used, often linked to a person, so using knowledge about the attacker significantly simplifies the process of breaking passwords.

¹ C Kaufman, R Perlman, M Speciner, 'Network Security--Private Communication in a Public World', Prentice Hall 1995

LAB 10

Many different entities today use OSINT for their purposes, not always legal.



2

Figure 1 Actors interested in OSINT

2. Required virtual machines

- Kali
- Metasploitable 2 or 3

3. Prerequisites

Get familiar with the following elements:

- whois
- dns
- fierce
- host
- Dmitry
- Traceroute
- p0f
- hping3/arping/fping/npin
- nbtscan

² <https://cybersecurity-magazine.com/an-introduction-to-open-source-intelligence-osint/>

4. Problems and questions

- I. What is the technical idea behind OS fingerprinting?
- II. Why OS fingerprinting can be important for security?
- III. What is a difference between passive and active OS fingerprinting?
- IV. Is it possible to protect your systems from OS fingerprinting?
- V. Is it possible to fool intruder and to show him that your host is not alive?
- VI. What is DNS zone transfer and what is a risk related to this mechanism?
- VII. Is it legal to use OSINT methods to get sensitive information?
- VIII. What is the biggest threat in context of security and OSINT methods?
- IX. How to protect your sensitive data from OSINT search?

5. Tasks

- I. Select one well know domain (e.g. `www.pwr.edu.pl`)
Try to gather some more specific information about the domain and its owner:
e.g. who have registered the domain and when, till when it is valid, is it using cloudflare or other DDOS protection,
- II. Query the whois database about that domain
`whois example.com`
- III. collect information about the DNS servers and the corresponding records of a target domain:
 - a. Use the host command line tool to lookup the IP address of a host from a DNS server
`host www.example.com`
`host -l example.com ns4.isp.com`
 - b. Use the dig command to do DNS interrogation
`dig example.com any`
`dig @8.8.8.8 example.com`
`dig @8.8.8.8 example.com MX`
`dig -x 8.8.8.8`
`dig example.com +trace`
`dig +noall +answer`
 - Find the primary DNS for a given domain
 - Try to find out what is TTL and if the requested domain was cached by DNS.
 - Find out how long time ago the given domain was requested at some DNSs (e.g. 1.1.1.1, 8.8.8.8, local DNS,...)
- IV. Utilize dnsenum
`dnsenum example.com`
`dnsenum -f dns.txt example.com`
- V. Find all of the IP addresses and hostnames of a target
`fierce -dns example.com -threads 3`

LAB 10

- VI. Get network routing information
- a. Using `tcptraceroute`
`traceroute www.example.com`
 - b. Using `tctrace`
`tctrace -i<network_interface> -d<targethost>`
- VII. Summarize your findings, compare tools and obtained results. What type of information do they provide? How malicious user can benefit from this type of information? Which tool is the most versatile?
- VIII. Try to find some Vulnerable Files or sensible information using google hacking method (e.g. in domain `pwr*.edu.pl` or in some other domain):
- a. Search for documents files (`.doc`, `.docx`, `.txt`, `.xls`, `pdf`,....)
 - b. Search for documents with some specific content (e.g. `grade`, `password`, `points`, `addresses`, ...)
 - c. Create statistics of findings (number of files, number of IP addresses, number of users, ...)
 - d. Find some interesting data using selected dorks from
`https://www.exploit-db.com/google-hacking-database/`
- IX. Use theharvester to collect e-mail accounts, username, and hostname/subdomains:
`thearvester -d example.com -l 100 -b linkedin`
for a given domain name try to search data using different data sources (e.g. baidu, bing, yahoo or use all)
- X. Using `https://nvd.nist.gov/vuln/search` search for some vulnerabilities in some type of the service (**`ssh`**, **`ftp`**, **`ssl`**, **`apache`**, **`qnap`**, **`western digital`** ...) and in next query related to some device (e.g. **`wireless router`**, **`asus wireless router`**, **`tp-link`**). Find some specific problem related to this service (device) - it is described as CVE - year - number.
Find critical vulnerabilities. Describe the vulnerability. Find the link to the webpage with exploit or/and detailed description of the vulnerability.
- XI. Using results from the previous point (e.g. `openssh 7.7` is vulnerable) search for the systems with this vulnerability (from point X) using
- a. `https://censys.io`
 - b. `https://www.shodan.io`
 - c. `https://zoomeye.org`
- Write how many vulnerable systems have been found. Which countries are the 'top most' vulnerable?